

HỌC VIỆN CÔNG NGHỆ BƯU CHÍNH VIỄN THÔNG



PHẠM HOÀNG DUY

BÀI GIẢNG

QUẢN LÝ AN TOÀN THÔNG TIN

HÀ NỘI 2018

Lời nói đầu

Sự phát triển mạnh mẽ của công nghệ mạng Internet và sự phổ biến rộng rãi của các ứng dụng máy tính khiến cho việc đảm bảo an toàn thông tin trong các hoạt động thường xuyên của các cơ quan, tổ chức cũng như cá nhân được quan tâm và đầu tư nhiều công sức và tiền của. Quản lý an toàn thông tin là một trong những môn cơ sở quan trọng dành cho sinh viên năm thứ 3, chuyên ngành an toàn thông tin. Môn học này cung cấp các kiến thức căn bản trong việc phát triển và quản lý các biện pháp đảm bảo an toàn thông tin. Môn học cũng giới thiệu các tiêu chuẩn an toàn phổ biến trong nước và quốc tế cũng như các quy định pháp luật về an toàn thông tin mà các giải pháp an toàn được khuyến nghị tuân theo và cần được tuân thủ. Ngoài ra, môn học cũng giới thiệu nguyên tắc và biện pháp giúp cho việc vận hành hệ thống đảm bảo an toàn cũng như duy trì việc hoạt động liên tục và xây dựng kế hoạch ứng phó khi có sự cố.

Bài giảng gồm 5 chương với nội dung như sau.

Chương 1 giới thiệu các mục tiêu và vấn đề cơ bản của quản lý an toàn thông tin. Với sự quan tâm ngày càng tăng về vấn đề an toàn, việc xây dựng các yêu cầu cũng như cách thức đảm bảo an toàn cho các nhiệm vụ, công việc của cơ quan/tổ chức chịu nhiều thách thức. Các yêu cầu và biện pháp an toàn không những phải tuân thủ các ràng buộc về mặt luật pháp mà cả về khía cạnh xã hội thể hiện sự đóng góp của cơ quan/tổ chức tới an toàn chung của cộng đồng.

Chương 2 trình bày các yêu cầu cơ bản về các chính sách an toàn thông tin của cơ quan hay tổ chức. Các chính sách an toàn này một mặt thể hiện mục tiêu mà cơ quan hay tổ chức đó cần đạt được, mặt khác chúng chứng tỏ sự tuân thủ với các quy định pháp luật cũng như sự đóng góp với xã hội và đối tác về việc đảm bảo an toàn thông tin. Phần tiếp theo của chương giới thiệu các ràng buộc về mặt pháp lý cũng như các hoạt động trong lĩnh vực thông tin và liên lạc của cá nhân và tổ chức cần phải tuân thủ trên lãnh thổ Việt Nam. Phần còn lại của chương giới thiệu các luật quan trọng liên quan đến vấn đề bảo vệ thông tin trong môi trường mạng của các nước Châu Âu, Mỹ và một số quốc gia trong khu vực.

Chương 3 trình bày về các tiêu chuẩn về an toàn thông tin phổ biến trên thế giới do Tổ chức tiêu chuẩn quốc tế ISO, Viện Tiêu chuẩn và Công nghệ Quốc gia Mỹ NIST ban hành. Chương này chủ yếu giới thiệu bộ tiêu chuẩn ISO 27000 và hệ thống tiêu chuẩn NIST. Phần cuối chương giới thiệu các tiêu chuẩn về an toàn thông tin của Việt Nam đã được công bố.

Chương 4 giới thiệu các khái niệm về khung quản lý an toàn thông tin nhằm cung cấp cái nhìn tổng thể về vấn đề an toàn và các chương trình an toàn (*security program*). Chương này tập trung trình bày cách thức phân tích và đánh giá rủi ro của các biện pháp kiểm soát với các vấn đề về an toàn hay các lỗ hổng giúp cho người quản lý có thể ra quyết định phù hợp cũng như xác định mức độ rủi ro chấp nhận được. Cách thức triển khai và đặc trưng

của các tiêu chuẩn thực tế cho việc phân tích rủi ro bao gồm OCTAVE, NIST SP 800-30 và ISO 27005 được giới thiệu chi tiết trong phần này.

Chương 5 nêu các yêu cầu căn bản đối với việc vận hành và sử dụng hệ thống cũng như các nhiệm vụ đảm bảo an toàn cần thực hiện. Vấn đề về quy trình quản lý thay đổi trong cấu hình hệ thống và các cách thức kiểm soát thiết bị và dữ liệu cũng được trình bày trong chương này.

Chương 6 là chương cuối của bài giảng tập trung vào vấn đề xử lý và đối phó với những tình huống sự cố. Chương này giới thiệu cách thức xây dựng các kế hoạch để khôi phục hệ thống khi sự cố cũng như đảm bảo khả năng hoạt động của hệ thống trong tình huống tài nguyên hạn chế.

Trong quá trình biên soạn bài giảng, dù tác giả có nhiều cố gắng song không thể tránh được những thiếu sót. Tác giả rất mong muốn nhận được các ý kiến phản hồi và góp ý cho các thiếu sót cũng như cập nhật và hoàn thiện nội dung của bài giảng.

Người biên soạn.

Mục lục

CHƯƠNG 1. TỔNG QUAN VỀ QUẢN LÝ AN TOÀN THÔNG TIN.....	9
1.1 Giới thiệu về quản lý an toàn thông tin	9
1.2 Chính sách và luật pháp an toàn thông tin.....	16
1.3 Các nguyên tắc trong quản lý an toàn thông tin	17
1.4 Phân loại thông tin và hệ thống thông tin.....	20
1.5 Các biện pháp quản lý an toàn thông tin	21
1.6 Tổ chức quản lý an toàn thông tin	22
1.7 Câu hỏi ôn tập.....	24
CHƯƠNG 2. HỆ THỐNG PHÁP LUẬT AN TOÀN THÔNG TIN CỦA VIỆT NAM VÀ CÁC NƯỚC	26
2.1 Các yêu cầu về chính sách, pháp luật.....	26
2.2 Các luật về an toàn thông tin của Việt Nam.....	29
2.3 Hệ thống pháp luật an toàn thông tin của các nước.....	38
2.4 Câu hỏi ôn tập.....	47
CHƯƠNG 3. HỆ THỐNG TIÊU CHUẨN AN TOÀN THÔNG TIN	49
3.1 Hệ thống tiêu chuẩn an toàn thông tin trên thế giới	49
3.2 Hệ thống tiêu chuẩn ISO/IEC.....	54
3.3 Hệ thống tiêu chuẩn NIST.....	60
3.4 Hệ thống tiêu chuẩn an toàn thông tin của Việt Nam.....	61
3.5 Câu hỏi ôn tập.....	62
CHƯƠNG 4. HỆ THỐNG QUẢN LÝ AN TOÀN THÔNG TIN	63
4.1 Bộ khung quản lý an toàn thông tin.....	63
4.2 Quản lý rủi ro	66
4.3 Nhận dạng, phân tích và đánh giá rủi ro.....	68
4.4 Các chiến lược kiểm soát rủi ro.....	74
4.5 Các thực tế về kiểm soát rủi ro	75
4.6 Câu hỏi ôn tập.....	85
CHƯƠNG 5. QUẢN LÝ VẬN HÀNH KHAI THÁC AN TOÀN.....	86
5.1 Nguyên tắc quản lý vận hành an toàn.....	86
5.2 Quản lý cấu hình.....	91
5.3 Kiểm soát thiết bị, dữ liệu	94
5.4 Trách nhiệm trong quản lý vận hành, khai thác	98
5.5 Câu hỏi ôn tập.....	99
CHƯƠNG 6. DUY TRÌ HOẠT ĐỘNG VÀ KHẮC PHỤC SỰ CỐ	101
6.1 Nguyên tắc duy trì hoạt động và khắc phục sự cố.....	101

6.2	Xây dựng kế hoạch duy trì hoạt động	105
6.3	Chiến lược khôi phục sự cố.....	110
6.4	Kiểm thử và cập nhật kế hoạch	113
6.5	Câu hỏi ôn tập.....	117

Danh mục các hình vẽ

Hình 1-1. Tương quan giữa các yêu cầu hệ thống	10
Hình 1-2. Quan hệ giữa các chủ thể an toàn thông tin.....	11
Hình 3-1. Bộ tiêu chuẩn ISO 27000.....	57
Hình 3-2. Các tài liệu bổ sung NIST SP 800-37.....	61
Hình 4-1. Khung kiến trúc an toàn SABSA.....	65
Hình 4-2. Các bước quản lý rủi ro	67
Hình 5-1. Các giai đoạn quản lý cấu hình.....	93
Hình 6-1. Các bước quản lý hoạt động liên tục.	102
Hình 6-2. Chu trình quản lý hoạt động liên tục.	104
Hình 6-3. Quy trình khôi phục sự cố	104
Hình 6-4. Đánh giá các tài nguyên cần thiết.....	108
Hình 6-5. Vị trí hoạt động và dự phòng.....	112

Danh mục các bảng

Bảng 2-1. Các văn bản pháp luật về an toàn thông tin	29
Bảng 4-1. Các tác nhân đe dọa và lỗ hổng.....	70
Bảng 4-2. Các đặc trưng các biện pháp kiểm soát.....	76
Bảng 4-3. Các rủi ro và ảnh hưởng.	80
Bảng 4-4. Phân tích rủi ro	80
Bảng 4-5. Đánh giá phương pháp	80
Bảng 4-6. Xác định mức độ rủi ro	83
Bảng 4-7. Đánh giá phương pháp	83
Bảng 4-8. Đánh giá phương pháp	85
Bảng 6-1. Các kiểu kế hoạch khôi phục.	113

Các từ viết tắt

ACL – Access Control List: Danh sách kiểm soát truy nhập

CIA – Confidentiality-Integrity-Availability: Bí mật, Toàn vẹn và Sẵn dùng

CII – Critical Information Infrastructure: Hạ tầng thông tin quan trọng

CSA – Cyber Security Agency: Cơ quan an ninh mạng

SOC – Security Operations Centre : Trung tâm giám sát hoạt động an ninh

CPU – Central Processing Unit: Đơn vị xử lý trung tâm

DAC – Discretionary Access Control: Kiểm soát truy nhập tùy chọn

DEP – Data Execution Prevention: Ngăn chặn thực thi dữ liệu

EAL - Evaluation Assurance Levels: Mức độ đánh giá an toàn

GUI – Graphic User Interface: Giao diện người dùng đồ họa

IDE – Integrated Development Environment: Môi trường phát triển tích hợp

IDS – Intrusion Detection System: Hệ thống phát hiện xâm nhập

ISO – International Standard Organisation: Tổ chức tiêu chuẩn quốc tế

ITU – International Telecommunication Union: Liên minh viễn thông quốc tế

LSM – Linux Security Module: Mô-đun an ninh Linux

ISP – Internet Service Provider: Nhà cung cấp dịch vụ Internet

MAC – Mandatory Access Control: Kiểm soát truy nhập bắt buộc

PC – Personal Computer: máy tính cá nhân

RBAC – Role Based Access Control: Kiểm soát truy nhập theo vai trò

TPM – Trusted Platform Module: Mô-đun hạ tầng tin cậy

WTO – World Trade Organization: Tổ chức thương mại thế giới

CHƯƠNG 1. TỔNG QUAN VỀ QUẢN LÝ AN TOÀN THÔNG TIN

Chương này giới thiệu các mục tiêu và vấn đề cơ bản của quản lý an toàn thông tin. Với sự quan tâm ngày càng tăng về vấn đề an toàn, việc xây dựng các yêu cầu cũng như cách thức đảm bảo an toàn cho các nhiệm vụ, công việc của cơ quan/tổ chức chịu nhiều thách thức. Các yêu cầu và biện pháp an toàn không những phải tuân thủ các ràng buộc về mặt luật pháp mà cả về khía cạnh xã hội thể hiện sự đóng góp của cơ quan/tổ chức tới an toàn chung của cộng đồng.

1.1 Giới thiệu về quản lý an toàn thông tin

1.1.1 Vấn đề an toàn thông tin

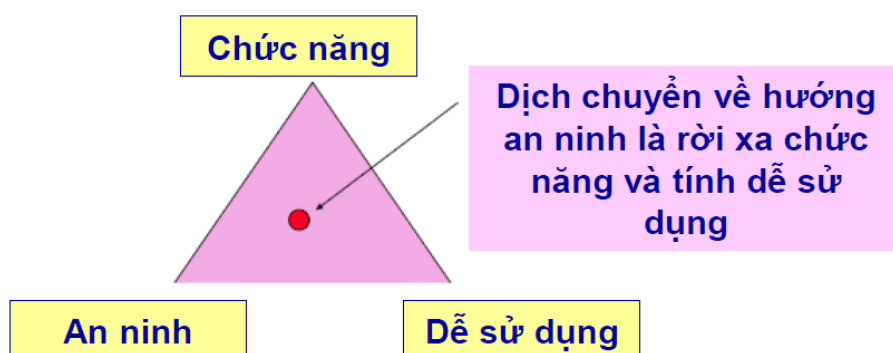
Trên thực tế các cơ quan hay tổ chức có rất nhiều vấn đề quan trọng cần quan tâm và giải quyết với các nhiệm vụ và công việc thường xuyên hơn là việc thực hiện an toàn thông tin. Chẳng hạn như:

- Công ty kinh doanh cần quảng bá và bán sản phẩm để tồn tại và phát triển
- Các cơ quan nhà nước đảm bảo xử lý các yêu cầu của công dân đúng luật và đúng hạn

Với sự phát triển của công nghệ, các cơ quan/tổ chức phải đối mặt với các vấn đề tiêu biểu:

- Mất trộm thông tin về bí mật kinh doanh, khách hàng, lừa đảo
- Các máy tính bị cài đặt phần mềm độc hại để tấn công cơ quan/tổ chức khác
- Các máy tính bị gián đoạn hay tê liệt không thể cung cấp dịch vụ đáp ứng nhu cầu của công ty cũng như khách hàng.

Các hoạt động bảo vệ thông tin và các thành phần thiết yếu bao gồm hệ thống và phần cứng mà sử dụng, lưu trữ, chuyển tiếp thông tin đó cho tới việc áp dụng các chính sách, các chương trình đào tạo và công nghệ có vai trò tối quan trọng để các công việc của cơ quan/tổ chức được diễn ra một cách bình thường. Đây là quá trình tiếp diễn và liên tục do những giới hạn về nguồn nhân lực và tài chính. Như vậy, cần cân bằng giữa nhu cầu đảm bảo an toàn cho các tài nguyên thông tin và việc thực hiện các hoạt động bình thường của cơ quan/tổ chức như thể hiện trong hình dưới đây.



Hình 1-1. Tương quan giữa các yêu cầu hệ thống

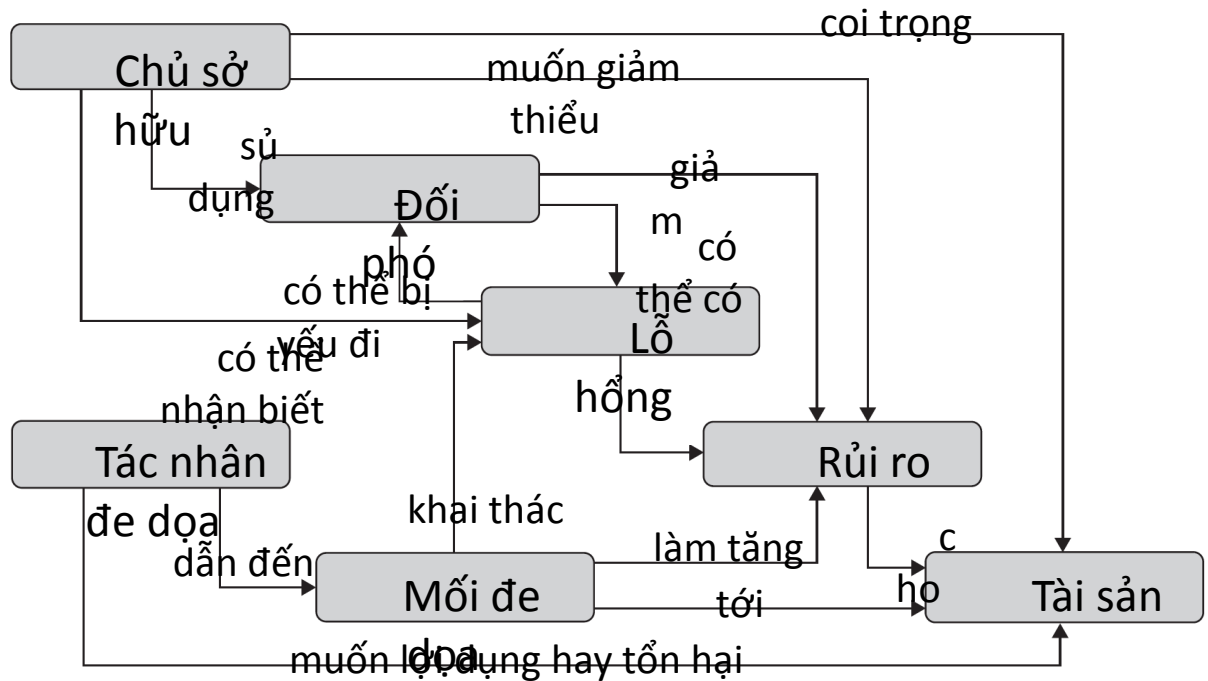
Các biện pháp bảo đảm an toàn cho hệ thống và hỗ trợ các chức năng của hệ thống để công việc được thực hiện một cách đầy đủ chứ không phải chỉ là các biện pháp hạn chế hay ràng buộc việc truy cập đến các phương tiện hay tài nguyên cần thiết. Đồng thời, các biện pháp kiểm soát cũng cần thuận tiện và dễ hiểu với người dùng để tránh việc việc chối bỏ hay thiếu sót khi thực hiện.

1.1.2 Các chủ thể an toàn

Để xác định một cách đúng đắn các vấn đề về an toàn cũng như sự ảnh hưởng của chúng lên những thông tin cần được bảo vệ, người ta thường sử dụng sơ đồ phân tích đánh giá liên quan giữa các chủ thể an toàn thông tin.

Hình 1-2 mô tả mối tương quan giữa ba đối tượng quan trọng trong phân tích và đánh giá an toàn là tài sản, chủ sở hữu tài sản và các tác nhân tác động lên tài sản đó. Việc nhận thức thích đáng quan hệ giữa các đối tượng này cho phép hiểu được giá trị của tài sản cần bảo vệ, mức độ rủi ro của mỗi đe dọa cũng như tính hiệu quả của các biện pháp đối phó. Các khái niệm cơ bản mô tả trong hình gồm có:

- *Tài sản (Asset)* là những thứ (có giá trị) thuộc sở hữu của cơ quan/tổ chức muốn được bảo vệ. Tài sản có thể là thứ cụ thể như cơ sở dữ liệu hoặc trừu tượng như tên tuổi (danh tiếng).
- *Tấn công (Attack)* là hành động lợi dụng lỗ hổng để xâm hại, ăn trộm, tung ra, làm hỏng hay phát tán, hay sửa đổi trái phép một tài sản.
- *Biện pháp đối phó (Counter-measure)* là các phương pháp nhằm giảm bớt hậu quả của các lỗ hổng. Biện pháp đối phó có thể thuần túy lô-gíc như áp dụng chính sách hay có thể là phản cứng như tường lửa.
- *Rủi ro (Risk)* được coi như khả năng sự kiện không mong muốn xảy ra thường ám chỉ đến các tổn thất có thể và thường được đối phó bằng việc triển khai: các công cụ kiểm tra giám sát; chuyển cho bên thứ ba như bảo hiểm; giảm nhẹ tổn thất do mất mát bằng lập kế hoạch đối phó với bất ngờ. Rủi ro thặng dư là rủi ro còn lại sau khi mọi biện pháp thận trọng đã được thực thi. Rủi ro chấp nhận được là rủi ro mà cơ quan/tổ chức chấp nhận sau khi đã hoàn tất chương trình quản lý rủi ro.



Hình 1-2. Quan hệ giữa các chủ thể an toàn thông tin

- *Đe dọa (Threat)* hướng tới việc phân loại các vấn đề có thể xảy ra cho tài sản của cơ quan/tổ chức. Đe dọa là các hành động chưa xảy ra nhưng khả năng xảy ra của chúng có thể thấy được.
- *Tác nhân đe dọa (Threat agent)* là các chủ thể cụ thể của các mối đe dọa không giới hạn ở con người.
- *Lỗ hổng (Vulnerability)* là cơ hội dẫn đến việc các mối đe dọa trở thành hiện thực và ảnh hưởng đến các tài sản. Lỗ hổng không chỉ giới hạn ở phần cứng, phần mềm mà có thể lỗi do quy trình.

Các mối đe dọa có thể được phân thành các loại như sau:

- Các hành động do lỗi của con người hay lỗi:
 - Các đe dọa này bao gồm các hoạt động được thực hiện vô tình bởi người dùng được phép.
 - Thiếu kinh nghiệm, đào tạo không đầy đủ, nhầm lẫn cũng như không tuân thủ quy trình, chính sách và quy định có thể biến nhân viên tốt thành tác nhân gây hại. Điều này dẫn đến việc đe dọa tính bí mật, toàn vẹn và sẵn sàng của dữ liệu
- Xâm phạm sở hữu trí tuệ. Sở hữu trí tuệ có thể gồm các bí mật thương mại, bản quyền, nhãn hiệu và bằng phát minh. Việc chiếm đoạt trái phép dẫn đến việc đe dọa an toàn thông tin.
- Các hành động xâm phạm và gián điệp:
 - Hoạt động của con người hay điện tử có thể dẫn đến lộ bí mật thông tin.

- Các tác nhân đe dọa có thể dùng nhiều phương pháp khác nhau để truy nhập tài sản thông tin. Có một số cách hợp pháp như sử dụng trình duyệt Web để thu thập thông tin. Song, gián điệp công nghệ là cách phi pháp. Tuy nhiên có thể sử dụng hành động thông thường như xem trộm hay hoạt động sử dụng công nghệ cao.
- Hành động làm biến đổi thông tin xảy ra khi kẻ tấn công hay nhân viên nội bộ đánh cắp thông tin và yêu cầu bồi thường để trả lại hay chấp thuận không công bố thông tin đó.
- Hành động phá hoại/ngầm liên quan đến việc phá hoại ngầm hệ thống máy tính hay công việc kinh doanh hay phá hoại hoặc phá hủy tài sản hay hình ảnh của cơ quan/tổ chức. Các hành động này có thể thay đổi từ hành động phá hoại lật vật của nhân viên cho đến phá hoại có chủ đích, từ kẻ bẻ khóa cho đến khủng bố mạng.
- Hành động của kẻ trộm là việc lấy đi trái phép tài sản của người khác. Tài sản có thể là đối tượng cụ thể hoặc điện tử hay trí tuệ. Giá trị tài sản bị mất đi khi nó bị sao chép hay lấy đi mà chủ sở hữu không biết.
- Các mối đe dọa phần mềm là những thứ liên quan đến chương trình máy tính được phát triển nhằm mục đích làm hỏng, phá hủy hay từ chối phục vụ cho hệ thống của cơ quan/tổ chức. Có thể kể một số dạng phần mềm có mục đích xấu như: vi-rút máy tính, sâu, hay phần mềm gián điệp (trojan horse).
- Thiên tai là mối đe dọa nguy hiểm nhất do chúng xảy ra mà ít có cảnh báo và nằm ngoài tầm kiểm soát của con người như hỏa hoạn, lũ lụt, động đất, sấm sét.
- Sai lệch các dịch vụ làm gián đoạn hệ thống thông tin do hệ thống cần sự hoạt động thành công của nhiều hệ thống hỗ trợ như mạng điện, hệ thống viễn thông, và thậm chí các nhân viên gác cổng. Các đe dọa dẫn đến sai lệch chất lượng dịch vụ thể hiện rõ ràng trong vụ tấn công. Việc này dẫn đến gián đoạn tính sẵn sàng.
- Hư hỏng phần cứng là các lỗi khi nhà sản xuất phân phối các thiết bị. Các lỗi này làm hệ thống hoạt động không như mong muốn dẫn đến dịch vụ không tin cậy hay thiếu tính sẵn sàng.
- Hư hỏng phần mềm là mối đe dọa thường xuyên do số lượng lớn các mã máy tính được viết, cung cấp và bán trước khi các lỗi được phát hiện và giải quyết. Đôi khi việc kết hợp phần cứng và phần mềm nhất định lại gây lỗi.
- Lỗi thời về công nghệ có thể xảy ra khi hạ tầng cũ hay lỗi thời dẫn đến hệ thống không ổn định và không tin cậy. Điều này dẫn đến rủi ro mất tính toàn vẹn dữ liệu do các cuộc tấn công tiềm tàng.

1.1.3 **Mục tiêu an toàn thông tin**

Các mục tiêu cốt lõi của an toàn thông tin là để đảm bảo tính sẵn dùng, tính toàn vẹn và bí mật cho các tài sản quan trọng. Mỗi tài sản sẽ yêu cầu các mức bảo vệ khác nhau.

Tất cả các biện pháp kiểm soát, cơ chế và biện pháp bảo vệ an ninh được thực hiện để cung cấp một hoặc nhiều mức bảo vệ này. Ngoài ra các rủi ro, mối đe dọa và lỗ hổng cần được đánh giá về khả năng phá vỡ một hoặc tất cả các nguyên tắc sẵn dùng, toàn vẹn và bí mật.

Bảo vệ tính sẵn sàng đảm bảo độ tin cậy và truy cập kịp thời vào dữ liệu và tài nguyên cho các cá nhân được ủy quyền. Thiết bị mạng, máy tính và ứng dụng phải cung cấp chức năng phù hợp để thực hiện theo cách có thể dự đoán được với mức hiệu suất có thể chấp nhận được. Các thiết bị và ứng dụng này sẽ có thể phục hồi từ trường hợp lỗi hay gián đoạn theo cách an toàn và nhanh chóng để năng suất không bị ảnh hưởng một cách tiêu cực. Cần có các cơ chế bảo vệ cần thiết để chống lại các mối đe dọa bên trong và bên ngoài có thể ảnh hưởng đến tính sẵn dùng và năng suất của tất cả các thành phần xử lý công việc. Việc đảm bảo sự sẵn có của các nguồn lực cần thiết trong cơ quan/tổ chức có vẻ dễ thực hiện hơn thực tế. Mạng có rất nhiều phần mà phải hoạt động (bộ định tuyến, máy chủ DNS, máy chủ DHCP, proxy, tường lửa...). Cũng như vậy, phần mềm có nhiều thành phần phải được thực hiện một cách lành mạnh (hệ điều hành, ứng dụng, phần mềm chống phần mềm độc hại). Có những vấn đề môi trường có thể ảnh hưởng tiêu cực đến hoạt động của cơ quan/tổ chức (hỏa hoạn, lũ lụt, các vấn đề về điện), thiên tai tiềm năng và hành vi trộm cắp hay tấn công vật lý. Cơ quan/tổ chức phải hiểu đầy đủ về môi trường hoạt động và các điểm yếu sẵn có của nó để có thể đưa ra các biện pháp đối phó thích hợp.

Tính toàn vẹn được duy trì khi đảm bảo tính chính xác và độ tin cậy của thông tin mà hệ thống cung cấp và bất kỳ sửa đổi trái phép nào đều được ngăn chặn. Các cơ chế phần cứng, phần mềm và truyền thông phải làm việc một cách hài hòa để duy trì và xử lý dữ liệu một cách chính xác và di chuyển dữ liệu đến các đích dự định mà không bị thay đổi bất thường. Các hệ thống và mạng phải được bảo vệ chống lại sự can thiệp và hư hỏng bên ngoài. Các môi trường đảm bảo thuộc tính an toàn này cần chắc chắn rằng những kẻ tấn công hoặc những sai lầm của người dùng không làm tổn hại đến tính toàn vẹn của các hệ thống hoặc dữ liệu. Khi kẻ tấn công chèn virus, bom logic hoặc cửa sau vào hệ thống dẫn đến tính toàn vẹn của hệ thống bị xâm phạm. Thông tin được lưu trữ trên hệ thống bị làm hỏng, sửa đổi một cách độc hại hoặc thay thế dữ liệu bằng dữ liệu không chính xác. Việc kiểm soát truy cập chặt chẽ, phát hiện xâm nhập và kỹ thuật băm có thể chống lại các mối đe dọa này.

Người dùng thông thường tác động đến toàn bộ hệ thống hoặc tính toàn vẹn của dữ liệu (mặc dù người dùng nội bộ cũng có thể phạm các hành động độc hại). Ví dụ, người dùng có truy cập tới toàn bộ ổ đĩa cứng có thể vô tình xóa các file cấu hình vì cho rằng việc xóa file không sao. Hoặc người dùng có thể chèn các giá trị không chính xác vào ứng dụng xử lý dữ liệu tính phí khách hàng 3 triệu thay vì 3 trăm nghìn. Việc sửa đổi dữ liệu không chính xác được lưu giữ trong cơ sở dữ liệu là cách phổ biến mà người dùng có thể vô tình làm hỏng dữ liệu và có thể có tác động lâu dài.

Bí mật đảm bảo rằng mức độ che giấu cần thiết được thực thi tại mỗi giao tiếp xử lý dữ liệu và ngăn chặn việc tiết lộ trái phép. Các biện pháp bảo mật này được sử dụng phổ biến khi dữ liệu nằm trên các hệ thống và thiết bị trong mạng, ngay khi nó được truyền đi và

khi đến đích. Những kẻ tấn công có thể ngăn chặn các cơ chế bảo mật bằng cách theo dõi mạng, nhìn trộm, ăn cắp các file mật khẩu, bẻ khóa các chương trình mã hóa và kỹ thuật xã hội.

Kỹ thuật xã hội là khi một người lừa một người khác để chia sẻ thông tin bí mật, ví dụ, bằng cách giả làm người được ủy quyền để có quyền truy cập vào thông tin đó. Kỹ thuật xã hội có thể có nhiều hình thức. Bất kỳ phương tiện truyền thông một-một có thể được sử dụng để thực hiện các cuộc tấn công sử dụng kỹ thuật xã hội. Người dùng có thể cố ý hoặc vô tình tiết lộ thông tin nhạy cảm bằng cách không mã hóa thông tin nhạy cảm trước khi gửi cho người khác, chia sẻ bí mật thương mại của công ty hoặc không sử dụng cẩn thận để bảo vệ thông tin bí mật khi xử lý thông tin đó.

Bảo mật có thể được đảm bảo bằng cách mã hóa dữ liệu khi nó được lưu trữ và truyền đi, thực thi kiểm soát truy cập chặt chẽ và phân loại dữ liệu, và bằng cách đào tạo nhân viên về các thủ tục bảo vệ dữ liệu thích hợp. Tính sẵn dùng, tính toàn vẹn và bảo mật là các nguyên tắc bảo mật quan trọng. Cần hiểu ý nghĩa của các biện pháp này và cách chúng được cung cấp bởi các cơ chế khác nhau, và sự thiếu vắng của chúng có thể ảnh hưởng tiêu cực đến cơ quan/tổ chức.

Trong thực tế, khi xử lý vấn đề an toàn thông tin nó thường chỉ được xem xét thông qua lăng kính của bí mật. Các mối đe dọa về tính toàn vẹn và tính sẵn dùng có thể bị bỏ qua và chỉ được xử lý sau khi chúng bị xâm phạm. Một số tài sản có yêu cầu quan trọng về bảo mật (bí mật thương mại của công ty), một số khác có yêu cầu quan trọng về tính toàn vẹn (giá trị giao dịch tài chính) và một số khác yêu cầu về tính sẵn sàng (máy chủ web thương mại điện tử). Nhiều người hiểu các khái niệm về bộ ba yêu cầu này nhưng có thể không hoàn toàn lường trước sự phức tạp của việc thực hiện các biện pháp kiểm soát cần thiết để cung cấp tất cả các mức độ bảo vệ cần thiết.

1.1.4 Quản lý an toàn thông tin

Các tin tức về vi rút gây thiệt hại hàng triệu đô la, tin tặc từ khắp nơi trên thế giới thu thập thông tin thẻ tín dụng từ các tổ chức tài chính hay các trang web của các tập đoàn lớn và các hệ thống của chính phủ bị tấn công vì lý do chính trị là những khía cạnh hấp dẫn về an toàn thông tin. Thực tế, những hoạt động này không phải là những gì mà công ty hoặc chuyên gia thường phải đối phó khi nói đến các nhiệm vụ an toàn hàng ngày

Quản lý an toàn đã thay đổi vì môi trường mạng, máy tính và các ứng dụng thông tin đã thay đổi. Trước đây, thông tin được sử dụng chủ yếu trong các máy chủ, hoạt động trong các mạng tập trung. Chỉ có một số người được phép truy cập và chỉ một nhóm nhỏ người biết cách làm việc của máy chủ. Những điều này làm giảm đáng kể rủi ro an ninh. Ngày nay, hầu hết các mạng tràn ngập các máy tính cá nhân hay thiết bị di động có phần mềm tiên tiến và khả năng xử lý mạnh; người dùng hiểu biết đủ về các hệ thống để có thể gây nguy hiểm; và thông tin không được tập trung trong một máy chủ. Thay vào đó, thông tin “sống” trên máy chủ, máy trạm, máy tính xách tay, thiết bị không dây, thiết bị di động, cơ

sở dữ liệu và các mạng khác. Thông tin đi qua các kết nối hữu tuyến và vô tuyến với tốc độ khó hình dung được so với thời gian trước đây.

Mạng Internet và mạng nội bộ không chỉ làm cho vấn đề an toàn phức tạp hơn nhiều mà còn khiến cho vấn đề này trở nên thiết yếu hơn nữa. Kiến trúc mạng lõi đã thay đổi từ môi trường máy tính độc lập sang môi trường tính toán phân tán làm độ phức tạp tăng lên theo cấp số nhân. Mặc dù việc kết nối với Internet tăng thêm nhiều chức năng và dịch vụ cho người dùng và nâng cao khả năng thể hiện hình ảnh của cơ quan/tổ chức với thế giới Internet song việc kết nối này mở ra vô số các rủi ro an toàn tiềm ẩn.

Ngày nay, đa số các cơ quan/tổ chức không thể hoạt động nếu không có máy tính và khả năng xử lý. Máy tính đã được tích hợp vào công việc của cơ quan/tổ chức cũng như cá nhân. Hầu hết các cơ quan/tổ chức đã nhận ra rằng dữ liệu của họ là tài sản cần được bảo vệ cũng như các tòa nhà, thiết bị máy móc và các tài sản vật chất khác của họ. Trong hầu hết các trường hợp, dữ liệu nhạy cảm của tổ chức thậm chí còn quan trọng hơn các tài sản vật chất này.

Vì mạng và môi trường hoạt động thay đổi nên cần có an ninh. An ninh không chỉ là các biện pháp kiểm soát kỹ thuật đưa ra để bảo vệ tài sản của cơ quan/tổ chức; các biện pháp kiểm soát này phải được quản lý và phần quan trọng của việc đảm bảo an toàn là quản lý các hành động của người dùng và các quy trình mà họ phải thực hiện.

Thực tiễn quản lý an toàn tập trung vào việc bảo vệ liên tục tài sản và tài nguyên của cơ quan/tổ chức. Quản lý an toàn bao gồm tất cả các hoạt động cần thiết để giữ cho một chương trình bảo mật hoạt động và phát triển. Việc quản lý này bao gồm quản lý rủi ro, lập tài liệu, triển khai và quản lý kiểm soát an toàn, quy trình và thủ tục, an ninh nhân sự, kiểm toán và đào tạo nâng cao nhận thức bảo mật liên tục.

Việc phân tích rủi ro xác định các tài sản quan trọng, phát hiện ra các mối đe dọa gây ra nguy cơ cho các tài sản đó và việc phân tích được sử dụng để ước tính thiệt hại có thể và tổn thất tiềm ẩn mà cơ quan/tổ chức có thể chịu đựng. Phân tích rủi ro giúp quản lý xây dựng ngân sách cần thiết để bảo vệ tài sản được xác định khỏi các mối đe dọa được xác định và phát triển các chính sách an toàn giúp định hướng cho các hoạt động an ninh.

Các biện pháp kiểm soát được xác định, triển khai và duy trì để giữ rủi ro an toàn của tổ chức ở mức có thể chấp nhận được. Các biện pháp kiểm soát có thể bao gồm:

- Kiểm soát quản trị: yêu cầu về an toàn, quản lý rủi ro, đào tạo
- Kiểm soát kỹ thuật : phần cứng hay phần mềm như tường lửa, kiểm soát truy nhập, phát hiện xâm nhập
- Kiểm soát vật lý: biện pháp bảo vệ các phương tiện, tài sản như nhà xưởng, phòng ốc

Bên cạnh đó, giáo dục và nâng cao nhận thức an toàn đưa thông tin về các biện pháp kiểm soát đến từng nhân viên trong cơ quan/tổ chức để mọi người được thông báo đầy đủ và có thể dễ dàng làm việc hướng tới các mục tiêu an ninh tương tự.

Tóm lại, việc quản lý an toàn thông tin mô tả các biện pháp kiểm soát cần thiết triển khai để đảm bảo quản lý được các rủi ro về mất, lạm dụng, lộ bí mật hay hư hỏng các thông tin và tài sản hạ tầng thông tin của cơ quan/tổ chức. Hệ thống quản lý an toàn thông tin là một phần của hệ thống quản lý, dựa trên các tiếp cận rủi ro kinh doanh/công việc để thiết lập, triển khai, vận hành, giám sát, xem xét, duy trì và cải thiện an toàn thông tin.

1.2 Chính sách và luật pháp an toàn thông tin

1.2.1 Chính sách an toàn

Vấn đề trước tiên của việc quản lý an toàn là chính sách an toàn. Chính sách này là tài liệu xác định phạm vi bảo mật cần thiết của cơ quan/tổ chức và thảo luận về các tài sản cần bảo vệ cũng như các giải pháp an toàn để đảm bảo mức độ bảo vệ cần thiết. Chính sách an toàn cho biết một cách tổng quát về nhu cầu đảm bảo an toàn của cơ quan/tổ chức. Các chính sách này định nghĩa các mục tiêu an toàn chính và vạch ra khung bảo mật của cơ quan/tổ chức.

Chính sách an toàn cần phác thảo một cách khái quát các mục tiêu và thực tiễn an ninh cần được sử dụng để bảo vệ lợi ích quan trọng của cơ quan/tổ chức. Bên cạnh đó, chính sách này thảo luận về tầm quan trọng của an ninh đối với mọi khía cạnh của hoạt động hay công việc thường xuyên và tầm quan trọng của sự hỗ trợ của các cán bộ cấp cao để thực hiện an ninh. Chính sách an toàn được sử dụng để phân công trách nhiệm, xác định vai trò, chỉ định các yêu cầu kiểm toán, phác thảo quy trình thực thi, cho biết các yêu cầu tuân thủ và xác định các mức độ rủi ro có thể chấp nhận được.

1.2.2 Đạo đức và luật pháp

Ở góc độ xã hội, thông thường con người chọn lọc từ bỏ một số khía cạnh tự do cá nhân để đảm bảo trật tự xã hội. Các quy định với các thành viên trong cộng đồng được tạo ra để cân bằng các quyền tự khẳng định bản thân đối chọi với các yêu cầu của toàn thể cộng đồng được coi là luật. Luật pháp là các quy định bắt buộc hay cấm một số hành vi nhất định; chúng được xây dựng dựa trên đạo đức mà xác định các hành vi chấp nhận được trong xã hội. Luật pháp đi kèm với cơ quan quyền lực để quản lý và thực thi các quy định của mình.

Đạo đức được phát triển dựa trên cơ sở các tập tục văn hóa như thái độ đạo đức hay thói quen của một nhóm cụ thể. Thông thường, đạo đức có tính ràng buộc thấp hơn so với luật pháp ở khía cạnh thực hiện. Việc vi phạm các quy định của luật pháp thường được các cơ quan thực thi luật pháp theo dõi, ngăn chặn và chấm dứt các hành vi này của cá nhân hay tổ chức. Xử phạt hành vi vi phạm như bồi thường hay nộp phạt được coi là đủ để khôi phục tư cách của cá nhân hay tổ chức trong các hoạt động tiếp theo. Tuy nhiên, việc xử lý các hành động vi phạm đạo đức không đơn giản như vậy. Các hành vi vi phạm các giá trị đạo đức được cộng đồng thừa nhận có ảnh hưởng rất nghiêm trọng và lâu dài đến các cá

nhân hay tổ chức vi phạm. Các cơ quan/tổ chức phải dành rất nhiều thời gian và công sức để khôi phục niềm tin của cộng đồng.

Hoạt động trong lĩnh vực an toàn thông tin, điều quan trọng với mỗi cá nhân cũng như cơ quan/tổ chức là hiểu được vai trò và ảnh hưởng của luật pháp, các quy định và các giá trị được cộng đồng và xã hội trân trọng cũng như việc tuân thủ các yêu cầu này tới các hoạt động của cơ quan/tổ chức. Các yêu cầu và ràng buộc này tác động đến các hoạt động cụ thể cũng như việc đề ra các chính sách an toàn như:

- Bảo vệ hoạt động của cơ quan/tổ chức
- Thiết kế hệ thống CNTT và các ứng dụng mới
- Quyết định thời hạn lưu giữ dữ liệu
- Phương pháp mã hóa dữ liệu nhạy cảm
-

Các cơ quan/tổ chức nghề nghiệp lớn thường xây dựng các quy định nghề nghiệp hay quy định về đạo đức để yêu cầu các thành viên tuân thủ để thể hiện nỗ lực và cống hiến tới sự phát triển bền vững và an toàn của cộng đồng như, Có thể kể đến các tổ chức như:

- Hiệp hội an toàn hệ thống thông tin (Information Systems Security Association) www.issa.org
- Hiệp hội máy tính (Association of Computing Machinery) www.acm.org
- Tập đoàn chứng nhận an toàn hệ thống thông tin quốc tế (International Information Systems Security Certification Consortium) www.isc2.org
- Hiệp hội an toàn thông tin Việt Nam VNISA vnisa.org.vn

1.3 Các nguyên tắc trong quản lý an toàn thông tin

Quản trị an toàn là tập hợp các thực tiễn liên quan đến hỗ trợ, xác định và chỉ đạo các nỗ lực an toàn của cơ quan/tổ chức. Quản trị an toàn có liên quan chặt chẽ và thường gắn bó với quản trị cơ quan/tổ chức và CNTT. Một số khía cạnh quản lý tác động lên cơ quan/tổ chức do yêu cầu phù hợp với quy định về pháp luật, ngược lại số khác ảnh hưởng bởi các hướng dẫn quy chuẩn công nghiệp hay yêu cầu bản quyền. Với công ty lớn, xuyên quốc gia thì vấn đề trở nên phức tạp hơn nhiều.

Toàn bộ công việc quản lý an toàn thỉnh thoảng cần phải được đánh giá và kiểm chứng. Vấn đề an toàn không nên và không thể chỉ coi là nhiệm vụ chuyên biệt của CNTT. Vấn đề an toàn ảnh hưởng tới mọi khía cạnh của cơ quan/tổ chức và nhân viên CNTT không thể xử lý hết được.

Các nguyên tắc cơ bản trong quản lý an toàn thông tin:

- Xây dựng các chức năng an toàn hướng tới mục tiêu, nhiệm vụ, kết quả và chiến lược của cơ quan/tổ chức
- Xây dựng các quy trình tổ chức
- Xây dựng vai trò và trách nhiệm với an toàn

- Xây dựng khung kiểm tra/kiểm soát
- Cần mẫn và cẩn trọng thích đáng

1.3.1 ***Xây dựng chức năng an toàn***

Việc lập kế hoạch quản lý an toàn cần điều chỉnh các chức năng an ninh/an toàn phù hợp với mục tiêu, nhiệm vụ, kết quả và chiến lược của cơ quan/tổ chức. Điều này bao gồm việc thiết kế và triển khai an toàn dựa trên các nguyên tắc hoạt động hay kinh doanh của cơ quan/tổ chức, các ràng buộc về kinh phí và tính sẵn có của nguồn lực.

Cách tiếp cận hiệu quả nhất để xử lý việc lập kế hoạch quản lý an toàn là từ trên xuống. Bộ phận đầu não và ban lãnh đạo chịu trách nhiệm khởi xướng và xây dựng các chính sách cho cơ quan. Các phòng ban quản lý hoàn chỉnh các chính sách này thành các hướng dẫn, quy định, thủ tục và tiêu chuẩn. Chuyên viên CNTT và nhân viên quản lý chịu trách nhiệm triển khai các cấu hình phù hợp với các tài liệu về quản lý an toàn. Cuối cùng người dùng cuối cần tuân thủ với yêu cầu an toàn cơ sở của cơ quan/tổ chức.

Việc xây dựng các kế hoạch quản lý phù hợp với các mục tiêu chiến lược, trung hạn và ngắn hạn của cơ quan/tổ chức.

1.3.2 ***Các quy trình tổ chức***

Quản trị an toàn cần hướng tới mọi khía cạnh của cơ quan/tổ chức bao gồm các quy trình tổ chức của các việc tiếp nhận, loại trừ. Cụ thể:

- Việc tiếp nhận là tăng mức độ rủi ro như lộ thông tin, mất dữ liệu, hay hệ thống không hoạt động
- Việc loại trừ dưới bất kỳ dạng nào như thanh lý tài sản hay cắt giảm nhân sự là thời điểm làm tăng rủi ro. Tài sản cần phải được tẩy sạch để ngừa rò rỉ thông tin. Nhân viên trước khi thôi việc cần được phỏng vấn và đánh giá lại các thỏa thuận và ràng buộc trong hợp đồng.

Quản trị an toàn cần được điều hành bởi hội đồng quản trị hay ban lãnh đạo nhằm để theo dõi và định hướng các hoạt động về an toàn cho cơ quan/tổ chức để thực hiện nhiệm vụ:

- *Quản lý và kiểm soát thay đổi.* Các thay đổi trong môi trường an toàn có thể dẫn đến các lỗ hổng, trùng lặp, sai lệch mục tiêu, và thiếu sót dẫn đến các lỗ hổng mới. Cách đối phó duy nhất là quản lý thay đổi một cách có hệ thống thông qua việc lập kế hoạch chi tiết, kiểm tra, theo dõi, ghi nhật ký các hoạt động liên quan tới các cơ chế và công cụ an toàn.
Mục tiêu quan trọng nhất của việc quản lý này là đảm bảo không một thay đổi nào làm suy giảm hay mất tác dụng của hệ thống an toàn.
- *Phân loại dữ liệu.* Việc phân loại dữ liệu là cách thức chủ yếu để bảo vệ dữ liệu dựa trên yêu cầu về tính bí mật, nhạy cảm của chúng. Sẽ không hiệu quả khi bảo vệ tất cả các dữ liệu đều như nhau. Việc phân loại giúp xây dựng mức độ

nỗ lực, khi phí và nguồn lực cần phân bổ để bảo vệ dữ liệu và các biện pháp kiểm soát truy nhập tới nó.

Quá trình phân loại dữ liệu sắp xếp các mục, đối tượng, và chủ thể ... vào trong các nhóm tương tự nhau dựa trên các yếu tố như giá trị, chi phí, rủi ro, đặc quyền ...

1.3.3 *Vai trò và trách nhiệm an toàn*

Vai trò an toàn là phần việc mà mỗi cá nhân tham gia vào trong kế hoạch tổng thể về quản trị và triển khai an toàn bên trong cơ quan/tổ chức. Các vai trò an toàn không nhất thiết được mô tả trong nhiệm vụ do chúng không hoàn toàn cố định hay tách biệt.

Nắm vững vai trò an toàn/an ninh giúp mọi người xây dựng cơ chế hỗ trợ và liên lạc bên trong cơ quan/tổ chức. Cơ chế này cho phép triển khai và thực hiện (bắt buộc) các chính sách an toàn. Các vai trò tiêu biểu: quản lý cao cấp, chuyên viên an toàn, chủ dữ liệu, bảo vệ dữ liệu, người dùng, kiểm toán/giám sát...

Việc phân định các vai trò có tác dụng quan trọng với môi trường được bảo vệ và hữu ích cho việc xác định trách nhiệm và liên đới cũng như xây dựng phân cấp quản lý.

1.3.4 *Hệ thống kiểm soát*

Xây dựng hệ thống an toàn cho cơ quan/tổ chức thường cần làm nhiều việc hơn là vạch ra các ý tưởng. Việc quan trọng đầu tiên với quản lý an toàn là xem xét hệ thống kiểm soát (*control framework*) hay các giải pháp an toàn một cách tổng thể. Thay vì tự xây dựng, cơ quan/tổ chức có thể xem xét các giải pháp/hệ thống kiểm soát an toàn có sẵn được khuyến nghị hay đề xuất bởi các tổ chức tiêu chuẩn hay hiệp hội nghề nghiệp mà phù hợp với nhu cầu của riêng mình. Có thể kể tên một số khung kiểm soát tiêu biểu như COBIT (*Control Objectives for Information and related Technology*), ISO 27001/2, NIST 800-53.

COBIT thường được các giám đốc điều hành sử dụng để thực hiện thành công các chính sách và thủ tục quan trọng của tổ chức. Ngoài ra, nó thường được sử dụng để kết hợp các biện pháp kiểm soát, các vấn đề kỹ thuật và các rủi ro trong một tổ chức. COBIT được quản lý bởi ISACA (Hiệp hội Kiểm toán và Kiểm soát Hệ thống Thông tin) và duy trì cập nhật tiêu chuẩn và ngang hàng với công nghệ hiện tại. Nó là một tiêu chuẩn được chấp nhận trên toàn cầu và hàm chứa nhiều hơn là phạm vi an toàn thông tin mà các tiêu chuẩn khác được giới hạn. Mặt khác COBIT có thể dễ dàng hơn khi triển khai một phần mà không yêu cầu phân tích và cam kết toàn diện của cơ quan/tổ chức.

ISO 27001/2 là tiêu chuẩn rất được tôn trọng và được biết đến rộng rãi. Bên cạnh đó chúng được công nhận và hiểu bởi những người quen thuộc với các tiêu chuẩn ISO. Tiêu chuẩn này cho phép các nhà quản lý hệ thống xác định và giảm thiểu các khoảng trống và chồng chéo trong vùng tác dụng của tiêu chuẩn này.

NIST bao gồm tất cả các bước trong quản lý rủi ro đề cập đến việc lựa chọn các biện pháp kiểm soát an toàn và được các tổ chức liên bang của Hoa Kỳ sử dụng để đáp ứng các

yêu cầu của hệ thống quản lý an toàn thông tin. Mức độ chi tiết trong việc thực hiện dựa trên NIST là đáng kể. Nếu cơ quan/tổ chức không muốn dành thời gian vào việc tùy chỉnh khung kiểm soát cụ thể của họ thì có thể sử dụng NIST với giả định mức độ chi tiết phù hợp các mục tiêu của nó.

1.3.5 *Cần mẫn và cần trọng thích đáng*

Cần trọng giúp bảo vệ lợi ích của cơ quan/tổ chức còn cần mẫn giúp duy trì các nỗ lực bảo vệ. Việc cần trọng thể hiện qua việc phát triển các cơ chế an toàn chính tắc (*formal security*) bao gồm các chính sách, tiêu chuẩn, hướng dẫn và các thủ tục. Việc cần mẫn thực thi các cơ chế an toàn này lên hạ tầng CNTT một cách đầy đủ.

An toàn về hoạt động là việc duy trì liên tục việc cần trọng và cần mẫn bởi tất cả các bên trong cơ quan. Như vậy giúp loại trừ các bất cần hay thiếu sót khi có sự cố an toàn.

1.4 Phân loại thông tin và hệ thống thông tin

Việc phân loại cho các dạng dữ liệu khác nhau cho phép cơ quan/tổ chức công ty đánh giá chi phí và tài nguyên cần để bảo vệ từng loại dữ liệu bởi vì không phải tất cả dữ liệu đều có cùng giá trị với mỗi cơ quan/tổ chức. Có rất nhiều thông tin được tạo ra và duy trì trong quá trình hoạt động. Lý do để phân loại dữ liệu là sắp xếp dữ liệu theo độ nhạy cảm của nó đối với sự mất mát, tiết lộ hoặc không có sẵn. Khi dữ liệu được phân loại theo mức độ nhạy cảm của nó, người ta có thể quyết định những biện pháp kiểm soát an toàn nào là cần thiết để bảo vệ các loại dữ liệu khác nhau. Điều này đảm bảo rằng các tài sản thông tin nhận được mức bảo vệ thích hợp và các phân loại cho biết mức độ ưu tiên của bảo vệ an toàn đó. Mục đích chính của phân loại dữ liệu là cho biết mức độ bảo mật, tính toàn vẹn và tính sẵn sàng bảo vệ cần thiết cho từng loại tập dữ liệu.

Phân loại dữ liệu giúp đảm bảo dữ liệu được bảo vệ theo cách hiệu quả nhất về chi phí. Bảo vệ và duy trì dữ liệu tiêu tốn tiền của nhưng điều quan trọng là phải chi tiêu số tiền này cho thông tin thực sự cần bảo vệ. Mỗi loại cần có các yêu cầu xử lý riêng biệt và các thủ tục liên quan đến cách dữ liệu đó được truy cập, sử dụng và hủy. Ví dụ trong công ty, thông tin bí mật có thể được truy cập chỉ bởi quản lý cấp cao và một vài người trong toàn công ty. Để xóa dữ liệu này một cách chính xác khỏi phương tiện lưu trữ có thể cần phải thực hiện các quy trình khử bằng xung điện hoặc xóa zero.

Việc phân loại hệ thống thông tin cũng có yêu cầu tương tự như phân loại thông tin nhằm giúp cho cơ quan/tổ chức hiểu được mức độ quan trọng và triển khai các biện pháp bảo vệ phù hợp với hệ thống thông tin đang sở hữu.

Các thức phân loại thông tin và hệ thống thông tin tùy thuộc vào các áp dụng cơ quan/tổ chức. Tuy nhiên các tiêu chí khái quát nhất có thể gồm:

- Mức độ hữu ích
- Giá trị/chi phí
- Liên kết với cá nhân nào

- Đánh giá tổn thất khi lộ hay bị sửa đổi thông tin hay hệ thống bị xâm nhập
- Yêu cầu của quốc gia
- Các truy nhập được phép
- Các ràng buộc/hạn chế với thông tin và hệ thống

Có một số mô hình tiêu chuẩn hỗ trợ việc phân loại dữ liệu dựa trên các mô hình chính tắc như Bell-La Padula, Biba, Clark-Wilson. Mô hình Bell-La Padula được áp dụng rộng rãi trong cơ quan chính quyền và quân sự của Hoa Kỳ với các lớp theo mức độ giảm dần bao gồm: tối mật (*top secret*), bí mật (*secret*), bảo mật (*confidential*), nhạy cảm nhưng chưa phân loại (*sensitive but unclassified*), chưa được phân loại (*unclassified*).

Chính phủ Việt Nam ban hành Nghị định số 85/2016/NĐ-CP về bảo đảm an toàn hệ thống thông tin theo cấp độ trong đó thông tin được phân loại thành 4 mức gồm có thông tin công cộng, thông tin riêng, thông tin cá nhân và thông tin bí mật nhà nước. Các hệ thống thông tin được phân loại theo nghiệp vụ bao gồm hệ thống nội bộ, hệ thống phục vụ người dân và cơ quan/tổ chức, hệ thống cơ sở hạ tầng,... Nghị định này cũng cung cấp các tiêu chí để xác định các 5 cấp độ khác nhau của hệ thống thông tin.

1.5 Các biện pháp quản lý an toàn thông tin

Để quản lý an toàn thông tin một cách hiệu quả cần thực hiện nhiều biện pháp khác nhau. Dưới đây trình bày các biện pháp và bước tiêu biểu.

- *Xây dựng chính sách.* Việc xây dựng chính sách quyết định sống còn đến việc đảm bảo an toàn cho cơ quan/tổ chức. Các chính sách này giúp xác định tính đúng đắn của các mục tiêu an toàn đề ra cũng như sự phù hợp của các mục tiêu an toàn với các công việc và nhiệm vụ của cơ quan/tổ chức cần thực hiện để tồn tại và phát triển.
- *Lập kế hoạch xây dựng khung an toàn/chương trình an toàn.* Việc xem xét thực tiễn hoạt động và các biện pháp kiểm soát sẵn có trong các khuyến nghị và các tiêu chuẩn cho phép cơ quan/tổ chức lựa chọn được cách thức phù hợp để đảm bảo các nhiệm vụ và công việc của mình được bảo vệ một cách phù hợp và cân bằng giữa yêu cầu về an toàn và các chi phí cho các biện pháp bảo vệ.
- *Đánh giá kết quả (hiệu năng)* cho phép xác định và kiểm chứng tính đúng đắn và hiệu quả của các biện pháp an toàn được triển khai. Bên cạnh đó việc đánh giá cho phép xác định các lỗ hổng xuất hiện trong quá trình hoạt động và vận hành của cơ quan/tổ chức.
- *Quản lý thay đổi* trong quá trình hoạt động của cơ quan/tổ chức giúp việc ứng phó và kiểm soát các biến động được tốt hơn. Điều quan trọng hơn là các biến động này không làm nảy sinh các lỗ hổng mới hay vấn đề với an toàn thông tin. Các thay đổi này rất đa dạng có thể xuất phát từ việc thay đổi mục tiêu của cơ

quan/tổ chức, biến động về công nghệ, thay đổi về chính sách hay quy định của nhà nước hay các tổ chức đối tác quốc tế.

- *Quản lý rủi ro* nhằm xác định, đánh giá các vấn đề an toàn với các tài sản cần bảo vệ của cơ quan/tổ chức cũng như biện pháp kiểm soát để đối phó với trường hợp hệ thống bị xâm phạm an toàn. Việc quản lý rủi ro cung cấp cái nhìn chi tiết về các mối đe dọa, mức độ tác động và chi phí để khắc phục mối đe dọa cho phép cơ quan/tổ chức xử lý một cách hiệu quả các lỗ hổng trong quá trình hoạt động của mình.
- *Quản lý vận hành an toàn* hướng tới việc triển khai và thực hiện một cách đầy đủ các biện pháp kiểm soát với hệ thống thông tin của cơ quan/tổ chức.
- *Xử lý sự cố* đối phó với trường hợp hệ thống bị xâm phạm các yêu cầu an toàn. Mục tiêu quan trọng của việc xử lý sự cố là đảm bảo việc hoạt động tối thiểu của cơ quan/tổ chức trong quá trình xảy ra sự cố, khắc phục và vượt qua các hậu quả của sự cố giúp cho cơ quan/tổ chức có thể tiếp tục hoạt động sau này.
- *Đào tạo nâng cao nhận thức an toàn* nhằm cung cấp thông tin đầy đủ và đúng đắn về các vấn đề an toàn thông tin cũng như các biện pháp kiểm soát cần thiết tới mọi người dùng và nhân viên của cơ quan/tổ chức. Việc này không chỉ giới hạn ở các chuyên gia và nhân viên chịu trách nhiệm về an toàn thông tin. Trên thực tế, mọi người đều có trách nhiệm hiểu biết và thực thi một cách đầy đủ các yêu cầu và các biện pháp an toàn.

1.6 Tổ chức quản lý an toàn thông tin

Việc xác định rõ ràng vai trò và trách nhiệm trong việc quản lý an toàn thông tin quyết định tính hiệu quả của các biện pháp cũng như hiệu lực của các chính sách an toàn thông tin. Thực tế cho thấy, số lượng đáng kể các lãnh đạo cấp cao không thực sự hiểu rõ các rủi ro về an toàn cũng như trách nhiệm của họ với vấn đề an toàn hệ thống thông tin. Kết quả rất khó để có được sự quan tâm thích đáng tới các vấn đề an toàn cũng như các sáng kiến thúc đẩy an toàn thông tin.

Tổ chức hiệu quả với quản trị an toàn thông tin cần liên kết các mức quản lý của cơ quan/tổ chức:

- Ban lãnh đạo
- Quản lý cấp cao
- Ban điều hành về an toàn
- Giám đốc an toàn thông tin

Ban lãnh đạo chịu trách nhiệm xác lập các định hướng chiến lược và đảm bảo các rủi ro được quản lý một cách thích đáng cũng như sử dụng các tài nguyên và đánh giá kết quả (hiệu năng). Quản lý cấp cao hỗ trợ tích cực các sáng kiến từ ban quản lý. Nếu không có

sự hỗ trợ này các quản lý về an toàn khó vượt qua trở ngại từ các cấp quản lý khác để thực hiện hiệu quả các chính sách an toàn.

Việc tổ chức ban điều hành về an toàn hợp lý có tác dụng cải thiện hiệu quả của quản trị an toàn thông tin. Những người tham gia lý tưởng là các đại diện cấp cao chịu trách nhiệm quản lý hay vận hành cơ quan/tổ chức. Điều này giúp nhanh chóng xác định và ưu tiên các rủi ro mới xuất hiện và kênh thông tin quan trọng để phổ biến các thông tin quan trọng liên quan đến an toàn.

Do thay đổi về nhận thức vấn đề an toàn, các quản lý về an toàn thông tin được tăng trách nhiệm và quyền lực trong nhiều lĩnh vực. Một số cơ quan xây dựng chức danh giám đốc về an toàn thông tin phụ trách:

- Xây dựng chi tiết các chiến lược hay chính sách an toàn thông tin
- Tư vấn cho lãnh đạo cấp cao về các vấn đề liên quan đến an toàn cũng như báo cáo trực tiếp lên lãnh đạo cấp cao và ban lãnh đạo
- Quản lý các chương trình an toàn và việc triển khai
- Trao đổi với các lãnh đạo bộ phận khác để đảm bảo an toàn thông tin trên tất cả các bộ phận

Ban kiểm tra/kiểm toán phải được chỉ định bởi ban lãnh đạo để giúp họ xem xét và đánh giá các hoạt động nội bộ của công ty, hệ thống kiểm toán nội bộ và tính minh bạch và chính xác của báo cáo tài chính để các khách hàng và đối tác tiếp tục tin tưởng vào cơ quan/tổ chức. Mục tiêu của ban này là cung cấp thông tin độc lập và cởi mở giữa ban lãnh đạo, quản lý của công ty, kiểm toán nội bộ và kiểm toán viên bên ngoài. Khi có sự cố vai trò của ủy ban kiểm toán đã chuyển từ theo dõi, giám sát và tư vấn sang thực thi và đảm bảo trách nhiệm của tất cả các thành viên liên quan.

Các vai trò và nhiệm vụ tiêu biểu về quản lý an toàn gồm có:

- *Quản lý cấp cao* là người chịu trách nhiệm tối cao về an toàn được duy trì bởi cơ quan/tổ chức và là người quan tâm nhất đến việc bảo vệ tài sản. Người quản lý cấp cao phải ký vào tất cả các văn bản về chính sách. Trên thực tế, tất cả các hoạt động phải được người quản lý cấp cao chấp thuận và phê duyệt trước khi chúng có thể được thực hiện. Không có chính sách an toàn hiệu quả nếu người quản lý cấp cao không cho phép và hỗ trợ chính sách đó. Người quản lý cấp cao là người chịu trách nhiệm về thành công hoặc thất bại chung của giải pháp an toàn và chịu trách nhiệm thực hiện việc theo dõi và thẩm định cẩn thận trong việc thiết lập an toàn. Mặc dù các nhà quản lý cấp cao chịu trách nhiệm cuối cùng về an toàn, họ hiếm khi thực hiện các giải pháp bảo mật. Trong hầu hết các trường hợp, trách nhiệm đó được giao cho các chuyên gia an ninh trong tổ chức.
- *Chuyên gia an ninh* hoặc vai trò của đội phản ứng sự cố máy tính được giao cho một nhóm, hệ thống và kỹ sư an toàn có kinh nghiệm và được đào tạo chịu trách nhiệm tuân thủ các chỉ thị do quản lý cấp cao uỷ nhiệm. Chuyên gia bảo mật có

trách nhiệm chức năng về an toàn bao gồm viết chính sách bảo mật và triển khai nó. Vai trò của chuyên gia bảo mật có thể được gán nhãn là vai trò chức năng hệ thống thông tin/CNTT. Vai trò chuyên môn bảo mật thường được gán cho một nhóm chịu trách nhiệm thiết kế và triển khai các giải pháp an toàn dựa trên chính sách an toàn được phê duyệt. Các chuyên gia bảo mật không phải là người ra quyết định mà họ là những người thực hiện. Tất cả các quyết định phải được để lại cho người quản lý cấp cao.

- *Chủ sở hữu dữ liệu.* Vai trò này được gán cho người chịu trách nhiệm phân loại thông tin cho việc triển khai và bảo vệ trong giải pháp an toàn. Chủ sở hữu dữ liệu thường là người quản lý cấp cao, người chịu trách nhiệm cuối cùng về bảo vệ dữ liệu. Tuy nhiên, chủ sở hữu dữ liệu thường ủy quyền trách nhiệm của các nhiệm vụ quản lý dữ liệu thực tế cho người quản lý dữ liệu.
- *Giám sát dữ liệu.* Vai trò giám sát dữ liệu được gán cho người dùng chịu trách nhiệm thực hiện việc bảo vệ theo quy định được xác định bởi chính sách an toàn và quản lý cấp cao. Người quản lý dữ liệu thực hiện tất cả các hoạt động cần thiết để đảm bảo việc bảo vệ đầy đủ cho bộ ba bảo mật, toàn vẹn và sẵn dùng của dữ liệu và để đáp ứng các yêu cầu và trách nhiệm được giao từ cấp trên. Các hoạt động này có thể bao gồm thực hiện và thử nghiệm các bản sao lưu, xác thực tính toàn vẹn dữ liệu, triển khai các giải pháp bảo mật và quản lý lưu trữ dữ liệu dựa trên phân loại.
- *Người dùng.* Vai trò người dùng (người dùng cuối hoặc người vận hành) được gán cho bất kỳ người nào có quyền truy cập vào hệ thống được bảo mật. Quyền truy cập của người dùng được gán với nhiệm vụ công việc của họ và bị giới hạn nên họ chỉ có đủ quyền truy cập để thực hiện các tác vụ cần thiết cho vị trí công việc của họ (nguyên tắc đặc quyền tối thiểu). Người dùng chịu trách nhiệm hiểu và duy trì chính sách bảo mật của một tổ chức bằng cách làm theo các quy trình hoạt động được quy định và hoạt động trong các thông số bảo mật được xác định.
- *Kiểm toán* có trách nhiệm xem xét và xác minh rằng chính sách an toàn được triển khai đúng và các giải pháp bảo mật được thực hiện đầy đủ. Vai trò kiểm toán có thể được chỉ định cho chuyên gia bảo mật hoặc người dùng được đào tạo. Người kiểm toán đưa ra các báo cáo về việc tuân thủ và tính hiệu quả cho quản lý cấp cao xem xét. Các vấn đề được phát hiện thông qua các báo cáo này được chuyển thành các chỉ thị mới được chỉ định bởi người quản lý cấp cao cho các chuyên gia bảo mật hoặc người quản lý dữ liệu.

1.7 Câu hỏi ôn tập

1. Trình bày và phân tích khái niệm về an toàn thông tin.
2. Nêu và phân tích tương quan giữa các khái niệm cơ bản: tài sản, tấn công, biện pháp, rủi ro, đe dọa.

3. Nêu và phân tích các khái niệm về quản trị, chính sách, luật pháp về an toàn thông tin.
4. Phân tích ảnh hưởng của đạo đức, chính sách và luật pháp tới hành vi sử dụng máy tính hay hệ thống mạng.
5. Phân tích ảnh hưởng qua lại giữa đạo đức, chính sách và luật pháp trong việc điều chỉnh hành vi sử dụng máy tính.
6. Trình bày nguyên tắc phân loại thông tin và hệ thống thông tin.
7. Tại sao cần phân loại thông tin và hệ thống thông tin.
8. Nêu và diễn giải các biện pháp quản lý an toàn thông tin tiêu biểu?
9. Trình bày cách thức tổ chức quản lý an toàn thông tin?

CHƯƠNG 2. HỆ THỐNG PHÁP LUẬT an toàn thông tin CỦA VIỆT NAM VÀ CÁC NƯỚC

Mục tiêu của chương này trình bày các yêu cầu cơ bản về các chính sách an toàn thông tin của cơ quan hay tổ chức. Các chính sách an toàn này một mặt thể hiện mục tiêu mà cơ quan hay tổ chức đó cần đạt được, mặt khác chúng chứng tỏ sự tuân thủ với các quy định pháp luật cũng như sự đóng góp với xã hội và đối tác về việc đảm bảo an toàn thông tin. Phần tiếp theo của chương giới thiệu các ràng buộc về mặt pháp lý cũng như các hoạt động trong lĩnh vực thông tin và liên lạc của cá nhân và tổ chức cần phải tuân thủ trên lãnh thổ Việt Nam. Phần còn lại của chương giới thiệu các luật quan trọng liên quan đến vấn đề bảo vệ thông tin trong môi trường mạng của các nước Châu Âu, Mỹ và một số quốc gia trong khu vực.

2.1 Các yêu cầu về chính sách, pháp luật

2.1.1 *Giới thiệu*

Trong cơ quan/tổ chức, các hệ thống máy tính và cách thức xử lý thông tin có mối quan hệ trực tiếp và then chốt với các nhiệm vụ và mục tiêu quan trọng của cơ quan/tổ chức trong quá trình hoạt động. Do tầm quan trọng này, quản lý cấp cao cần bảo vệ các yếu tố này với mức ưu tiên cao và dành sự hỗ trợ, tài chính, thời gian và tài nguyên cần thiết để đảm bảo rằng hệ thống, mạng và thông tin phục vụ cho công việc được bảo vệ theo cách hợp lý và hiệu quả nhất có thể.

Để kế hoạch an toàn thành công, kế hoạch này phải bắt đầu ở cấp cao nhất cũng như có ích và hiệu lực ở mọi cấp độ. Quản lý cấp cao cần xác định phạm vi an toàn và xác định những gì phải được bảo vệ và ở mức độ nào. Đội ngũ lãnh đạo phải nắm các quy định, luật pháp và các vấn đề trách nhiệm pháp lý cũng như chịu trách nhiệm tuân thủ các ràng buộc liên quan đến an toàn. Bên cạnh đó, ban lãnh đạo đảm bảo rằng cơ quan/tổ chức chấp hành đầy đủ nghĩa vụ của mình cũng như xác định những điều mong đợi từ nhân viên và hậu quả của việc không tuân thủ. Những quyết định này nên được thực hiện bởi những cá nhân chịu trách nhiệm cuối cùng khi việc vi phạm xảy ra. Thực tế phổ biến cho thấy, để đạt được các mục tiêu do quản lý cấp cao thiết lập và xác định cần kiến thức chuyên môn của các nhân viên phụ trách an toàn trong việc phối hợp và đảm bảo rằng các chính sách và biện pháp kiểm soát phù hợp được thực hiện.

2.1.2 *Các yêu cầu của chính sách*

Chính sách an toàn là một tuyên bố chung khái quát được quản lý cấp cao đưa ra trong đó xác định các vai trò an toàn trong cơ quan/tổ chức được thực hiện như thế nào. Chính sách an toàn có thể là quy tắc tổ chức; chính sách dành riêng cho vấn đề cụ thể hay cho hệ thống. Trong chính sách an toàn của cơ quan/tổ chức, đội ngũ quản lý xác định cách thức thiết lập chương trình an toàn, đưa ra các mục tiêu của chương trình, phân công trách

nhiệm, vạch ra các giá trị ngắn hạn và dài hạn về an toàn cũng như cách thực thi. Chính sách này phải giải quyết các luật, quy định và các vấn đề trách nhiệm pháp lý tương đối và cách chúng được chấp hành. Chính sách an toàn của cơ quan/tổ chức xác định phạm vi và hướng cho tất cả các hoạt động đảm bảo an toàn trong tương lai trong cơ quan/tổ chức. Chính sách an toàn cũng mô tả mức độ rủi ro mà quản lý cấp cao sẵn sàng chấp nhận.

Các dạng cơ bản của chính sách có thể bao gồm:

- Quy định đảm bảo rằng cơ quan/tổ chức tuân theo các tiêu chuẩn được thiết lập bởi các quy định ngành cụ thể. Chúng rất chi tiết và cụ thể cho một loại ngành. Các quy định có thể được sử dụng trong các tổ chức tài chính, cơ sở chăm sóc sức khỏe, tiện ích công cộng và các ngành khác do chính phủ quản lý.
- Tư vấn/Khuyến nghị nhằm khuyến khích một cách mạnh mẽ cho nhân viên về các hành vi và hoạt động nào nên và không nên diễn ra trong cơ quan/tổ chức. Các chính sách này cũng vạch ra các trường hợp có thể khi nhân viên không tuân thủ các hành vi và hoạt động đã thiết lập.
- Thông tin nhằm thông báo cho nhân viên về các vấn đề nhất định và thường là các hướng dẫn cá nhân về các vấn đề cụ thể liên quan đến cơ quan/tổ chức. Các chính sách này giải thích cách cơ quan/tổ chức tương tác với các đối tác, các mục tiêu và nhiệm vụ và cấu trúc báo cáo chung trong các tình huống khác nhau.

Các lĩnh vực cơ bản mà chính sách đề cập đến gồm có:

- Chính sách sử dụng được chấp nhận
- Chính sách quản lý rủi ro
- Chính sách quản lý lỗ hổng
- Chính sách bảo vệ dữ liệu
- Chính sách kiểm soát truy cập
- Chính sách duy trì hoạt động
- Chính sách thu thập log và kiểm toán
- Chính sách an toàn nhân sự
- Chính sách kiểm soát thay đổi
- Chính sách ứng phó sự cố

Các yêu cầu cơ bản cho việc thực hiện đầy đủ và thành công các mục tiêu an toàn của chính sách đó là:

- Phổ biến (phân phát): Mọi người trong cơ quan/tổ chức đều có thể đọc và xem xét các chính sách phù hợp.
- Đánh giá (đọc): Cơ quan/tổ chức cần phân phát các tài liệu theo dạng dễ hiểu dễ đọc cho mọi đối tượng nhân viên như tài liệu bằng nhiều ngôn ngữ
- Nhận thức (hiểu): Mỗi nhân viên đều hiểu các yêu cầu và nội dung của các chính sách

- Chấp thuận (đồng ý): Đảm bảo các nhân viên đồng ý tuân thủ chính sách bằng hành động hay xác nhận
- Thi hành nhất quán: Cơ quan/tổ chức cần đảm bảo chính sách được thực thi nhất quán bất kể tình trạng hay công việc của nhân viên

2.1.3 ***Chính sách, tiêu chuẩn và luật pháp***

Các tiêu chuẩn đề cập đến các hoạt động, hành động hoặc quy tắc bắt buộc. Chúng có thể là một quy trình hoặc một cách thức để thực hiện một giải pháp. Điều này liên quan đến công nghệ, phần cứng hoặc phần mềm đã có mà đã được chứng minh về hiệu quả. Đây có thể là một quy định hay hướng dẫn kỹ thuật thực thi được triển khai trên toàn cơ quan/tổ chức. Tiêu chuẩn đảm bảo an toàn của cơ quan/tổ chức có thể chỉ định cách sử dụng các sản phẩm phần cứng và phần mềm. Tiêu chuẩn cũng có thể được sử dụng để xác định hành vi người dùng mong đợi. Như vậy, các tiêu chuẩn cung cấp phương tiện để đảm bảo rằng các công nghệ, ứng dụng, thông số và quy trình cụ thể được thực hiện theo cách thống nhất (chuẩn) trên toàn tổ chức.

Với các mục tiêu của an toàn thông tin, các tiêu chuẩn là tập các tiêu chí mà hệ thống thông tin phải thực hiện. Cơ quan/tổ chức có thể có các tiêu chuẩn nội bộ của mình. Thông thường các tiêu chuẩn này được điều chỉnh cho phù hợp dựa trên một số thực tiễn tốt nhất từ bên ngoài. Việc áp dụng tiêu chuẩn phù hợp đảm bảo rằng các bài học kinh nghiệm đã được xem xét.

Chính sách của cơ quan/tổ chức triển khai các biện pháp kiểm soát trên hệ thống để làm cho nó đáp ứng tiêu chuẩn nào đó. Các tiêu chuẩn hỗ trợ và định hướng cho việc xây dựng chính sách. Tiêu chuẩn thường xác định yêu cầu tối thiểu nhưng có thể rất chi tiết về bản chất. Thực tế, quy định pháp luật hoặc thực tiễn đã được chấp thuận rộng rãi tạo ra các tiêu chuẩn. Sau đó, các tiêu chuẩn này trở thành tiêu chí cho quản trị hoặc chứng nhận và công nhận.

Tiêu chuẩn thường bắt đầu với các tiêu chuẩn công nghiệp. Theo thời gian, các tổ chức đại diện cho ngành công nghiệp phát triển và xuất bản các tiêu chuẩn. Những tiêu chuẩn này thường trở thành thước đo mà theo đó các nhà quản lý đánh giá các cơ quan/tổ chức. Cần phải cẩn trọng khi lệch quá xa các tiêu chuẩn của ngành. Việc không tuân thủ chúng có thể dẫn đến các hình phạt dân sự và pháp lý. Ví dụ như tiêu chuẩn bảo mật dữ liệu thẻ thanh toán (PCI DSS) có thể áp dụng mức phạt lên tới 50.000\$ /ngày cho việc vi phạm tiêu chuẩn đã công bố hay 500.000\$ cho mỗi sự vụ liên quan đến an toàn dữ liệu.

Ở góc độ xã hội, các hoạt động CNTT ảnh hưởng tới nhiều đối tượng cũng như lĩnh vực khác nhau nên chịu sự tác động của nhiều luật nhằm xác định và điều chỉnh cách hành vi cũng như kiểm soát việc truy nhập và sử dụng thông tin như:

- Sử dụng, trao đổi và phân phát dữ liệu
- Sử dụng máy tính cho việc xử lý, trao đổi dữ liệu
- Thông tin cá nhân

- Thông tin của tổ chức, cơ quan nhà nước
- Thương mại điện tử
- Ngân hàng điện tử
- Bản quyền
- Khủng bố và chống khủng bố

Các hoạt động của cơ quan/tổ chức cũng như các chính sách và tiêu chuẩn áp dụng cần pháp đáp ứng và tuân thủ một cách đầy đủ các quy định về luật pháp tác động lên cơ quan/tổ chức đó. Việc không chấp hành một cách đầy đủ các quy định này có thể dẫn đến các hậu quả rất nghiêm trọng từ phạt tiền đến gián đoạn việc hoạt động và thậm chí chấm dứt hoạt động của cơ quan/tổ chức.

2.2 Các luật về an toàn thông tin của Việt Nam

2.2.1 Các văn bản pháp luật :

Các văn bản pháp luật do quốc hội Việt Nam ban hành (Luật 80/2015/QH13):

1. Hiến pháp: có hiệu lực pháp lý cao nhất và quy định những vấn đề cơ bản của quốc gia
2. Bộ luật, luật: nhằm mục đích cụ thể hóa hiến pháp điều chỉnh các quan hệ xã hội trong các lĩnh vực đời sống nhà nước và xã hội.

Các văn bản dưới luật do các cơ quan có thẩm quyền ban hành và có hiệu lực pháp lý thấp hơn:

1. Pháp lệnh, nghị quyết của Ủy ban thường vụ Quốc hội;
2. Lệnh, quyết định của Chủ tịch nước.
3. Nghị định của Chính phủ; Quyết định của Thủ tướng Chính phủ.
4. Thông tư (thông tư liên tịch) của Bộ trưởng, Thủ trưởng cơ quan ngang bộ;

Bảng 2-1 dưới đây liệt kê các văn bản pháp luật đã được ban hành về lĩnh vực liên quan an toàn thông tin.

Bảng 2-1. Các văn bản pháp luật về an toàn thông tin

Số hiệu	Hình thức	Lĩnh vực	Trích yếu nội dung
---------	-----------	----------	--------------------

24/ 2018/ QH14	Luật	An ninh mạng	Quy định về hoạt động bảo vệ an ninh quốc gia và bảo đảm trật tự, an toàn xã hội trên không gian mạng; trách nhiệm của cơ quan, tổ chức, cá nhân có liên quan.
632/ QĐ- TTg	Quyết định	CNTT, điện tử, An toàn thông tin	Ban hành danh mục lĩnh vực quan trọng cần ưu tiên bảo đảm an toàn thông tin mạng và hệ thống thông tin quan trọng quốc gia
85/ 2016/ NĐ-CP	Nghị định	CNTT, điện tử	Về bảo đảm an toàn hệ thống thông tin theo cấp độ
108/ 2016/ NĐ-CP	Nghị định	CNTT, điện tử	Quy định chi tiết điều kiện kinh doanh sản phẩm, dịch vụ an toàn thông tin mạng
898/ QĐ- TTg	Quyết định	CNTT, điện tử	Phê duyệt phương hướng, mục tiêu, nhiệm vụ bảo đảm an toàn thông tin mạng giai đoạn 2016 - 2020
86/ 2015/ QH13	Luật	Viễn thông, CNTT, điện tử	Quy định về hoạt động an toàn thông tin mạng, quyền, trách nhiệm của cơ quan, tổ chức, cá nhân; mật mã dân sự; tiêu chuẩn, quy chuẩn kỹ thuật; kinh doanh trong lĩnh vực và phát triển nguồn nhân lực an toàn thông tin mạng; quản lý nhà nước.
1883/ QĐ- BTƯ	Quyết định	Cơ cấu tổ chức	Quy định chức năng, nhiệm vụ, quyền hạn và cơ cấu tổ chức của Trung tâm Tư vấn và hỗ trợ nghiệp vụ an toàn thông tin
893/ QĐ- TTg	Quyết định	CNTT, điện tử	Phê duyệt Đề án Tuyên truyền, phổ biến, nâng cao nhận thức và trách nhiệm về an toàn thông tin đến năm 2020
1281/ QĐ- BTƯ	Quyết định	CNTT, điện tử, Cơ cấu tổ chức	Quy định chức năng, nhiệm vụ, quyền hạn và cơ cấu tổ chức của Cục An toàn thông tin
05/ 2014/ TT- BTƯ	Thông tư	Lĩnh vực khác	Thông tư Quy định Danh mục sản phẩm, hàng hóa có khả năng gây mất an toàn thuộc trách nhiệm quản lý của Bộ Thông tin và Truyền thông
99/ QĐ- TTg	Quyết định	CNTT, điện tử	Phê duyệt Đề án "đào tạo và phát triển nguồn nhân lực an toàn, an ninh thông tin đến năm 2020"
22/ 2013/ QĐ- UBND	Quyết định	CNTT, điện tử	Ban hành Quy chế đảm bảo an toàn, an ninh thông tin trên môi trường mạng trong hoạt động của các cơ quan nhà nước trên địa bàn tỉnh Bến Tre